ShadowBench

Shadow AI agent discovery — nine-surface estate benchmark: results and tool grades

Run 2026-10-11 · corpus frozen by SHA-256 (139 files) · Project Nexus / ShadowScan repository, branch claude/inspiring-planck-443jts · results committed under benchmarks/shadowbench/results/2026-10-11/

Disclosure. This benchmark is not independent: the same maintainer wrote ShadowScan, the harness, the artifacts and the labels, with format knowledge derived from ShadowScan's own documentation. Labels were authored from vendor semantics and frozen before the published run; they were never changed because a tool missed or flagged an entity. Treat every number as offline evidence about these inputs, not as measured field precision or recall, and never as a second-person audit.

1 · What was measured

The corpus models **Vantor Logistics**, a fictional organization, as one estate of vendor-format artifacts across nine surfaces: code repositories, identity-provider exports, gateway logs, low-code platform exports, SaaS app inventories, cloud inventories, materialized endpoint home trees plus offline endpoint exports, network logs and runtime process exports. Ground truth is **137 labeled entities**: 87 positives (genuine AI agents or AI usage, four of them registered in the supplied agent registry), 27 controls (clearly non-AI) and 23 near-misses (AI-adjacent vocabulary without AI technology — flagging one is a false positive). Predictions attach to entities by unique anchors embedded in the artifacts; unattributed in-scope predictions are charged as false positives. The benchmark never executes corpus content: tools that enumerate MCP servers by launching them run with that behavior inert, and live network fingerprinting runs against loopback mock services mirroring the estate's model servers.

2 · Headline results

Tool	Srf	Found	Entity TP/FP/TN/FN	In-scope value P / R / F1	Estate recall
ShadowScan (Project Nexus) 0.1.2	9	83/87	83/8/42/4	92% / 95% / **93%**	95%
Snyk Agent Scan (mcp-scan) 0.6.8	1	9/87	9/0/50/78	100% / 47% / **64%**	9%
AgentDiscover 2.9.5	1	5/87	5/0/50/82	100% / 35% / **52%**	8%
AI-Infra-Guard 4.6.5	1	2/87	2/0/50/85	100% / 33% / **50%**	2%
SafeDep vet (ai discover) 1.20.0	2	11/87	11/0/50/76	86% / 29% / **43%**	12%
Numbat 0.2.0	1	4/87	4/0/50/83	100% / 21% / **35%**	4%
Agentic Radar 0.14.1	1	2/87	2/0/50/85	100% / 9% / **16%**	2%
AgentSight (local sessions) 1.0.34	1	1/87	1/0/50/86	100% / 5% / **10%**	1%
Cisco MCP Scanner 4.8.6	1	0/87	0/0/50/87	n/a / 0% / **n/a**	0%

Tool	Srf	Found	Entity TP/FP/TN/FN	In-scope value P / R / F1	Estate recall
power-pwn 6.0.0 · Cartography 0.143.0	—	not runnable by design (live M365 tenant + MSAL; live cloud APIs + Neo4j)			

Entity TP/FP/TN/FN count positives detected, negatives flagged, negatives left clean and positives missed on the tool's declared surfaces. In-scope counts only declared surfaces; estate-wide recall charges every tool for all nine. ShadowScan's registry layer classified all 83 detected positives correctly (79 shadow, 4 registered); no other tool reconciles against a registry.

3 · Value-level F1 by surface

Tool	code	ident	gatew	lowc	saas	cloud	endpt	netw	runt
ShadowScan (Project Nexus)	**96%** 22/1/1	**92%** 12/2/0	**80%** 6/2/1	**90%** 9/1/1	**87%** 10/2/1	**90%** 9/1/1	**100%** 19/0/0	**100%** 6/0/0	**100%** 6/0/0
Snyk Agent Scan (mcp-scan)	—	—	—	—	—	—	**64%** 9/0/10	—	—
AgentDiscover	**52%** 8/0/15	—	—	—	—	—	—	—	—
AI-Infra-Guard	—	—	—	—	—	—	—	—	**50%** 2/0/4
SafeDep vet (ai discover)	**23%** 3/0/20	—	—	—	—	—	**60%** 9/2/10	—	—
Numbat	—	—	—	—	—	—	**35%** 4/0/15	—	—
Agentic Radar	**16%** 2/0/21	—	—	—	—	—	—	—	—
AgentSight (local sessions)	—	—	—	—	—	—	**10%** 1/0/18	—	—
Cisco MCP Scanner	—	—	—	—	—	—	**n/a** 0/0/19	—	—

Cells read F1 with TP/FP/FN beneath; “—” is out of the tool's declared scope with no activity. Expected facts per surface: code n=23, identity n=12, gateway n=7, lowcode n=10, saas n=11, cloud n=10, endpoint n=19, network n=6, runtime n=6.

4 · Rankings and grades

Rubric: in-scope effectiveness 50% · estate coverage 25% · false-positive discipline 15% · operability (offline, no-execution, machine-readable output) 10%. Grades judge each tool on this corpus and this operating model; the per-surface matrix is the fairest single citation.

#	Tool	Grade	In-scope F1	Estate recall	Rationale
1	**ShadowScan (Project Nexus)** 0.1.2	**A**–	93%	95%	Only estate-wide system: 83/87 entities, 93% in-scope F1, 83/83 registry verdicts. Docked for 8 trap false positives and 4 self-hosted-inference misses. Conflict of interest: the benchmark lives in its repository.
2	**Snyk Agent Scan (mcp-scan)** 0.6.8	**B**–	64%	9%	Flawless on MCP client configs (100% precision, consent model executes nothing); blind to model stores, extensions and offline exports. B+ at its specialty.
3	**SafeDep vet (ai discover)** 1.20.0	**C+**	43%	12%	Widest third-party footprint (code + endpoint), near-Snyk endpoint inventory at 0.2 s per unit; code coverage is configs-only.
4	**AgentDiscover** 2.9.5	**C+**	52%	8%	Best third-party code recall: 5 of 6 positive repos, zero negatives flagged; facts are coarse and single-surface.
5	**AI-Infra-Guard** 4.6.5	**C+**	50%	2%	Perfect on network-reachable services (2/2 with versions and CVE context); most runtime entities are invisible to any network scanner.
6	**Numbat** 0.2.0	**C**–	35%	4%	Found exactly the 4 agents with at-rest transcripts; a usage-forensics tool graded on an inventory rubric.
7	**Agentic Radar** 0.14.1	**D**	16%	2%	2 of 6 repos, textbook framework layouts only; consistent with its 5% recall on the 87-repo code benchmark.
8	**AgentSight (local sessions)** 1.0.34	**D / Inc.**	10%	1%	Local-session fallback found 1/19; its primary eBPF mode is environment-blocked (fentry/fexit EPERM), so the thesis is untested.
9	**Cisco MCP Scanner** 4.8.6	**F***	n/a	0%	Zero discovery by design: it enumerates servers only by launching or connecting to them, which the no-execution benchmark forbids. A tool-content analyzer, not a discovery tool.
—	**power-pwn** 6.0.0 · **Cartography** 0.143.0	**Incomplete**	n/a	n/a	Not F: both require live estates by design (interactive M365/MSAL tenant auth; live cloud APIs into a running Neo4j). An offline corpus cannot measure them; they cover the surfaces where offline options are weakest.

5 · What the hard cases showed

Misses that matter. ShadowScan's four misses share one shape: self-hosted inference behind undocumented idioms — a text-generation-inference caller in an egress log, an n8n flow calling a self-hosted vLLM over plain HTTP, a markerless Kubernetes vLLM workload, and a niche Slack notetaker. Every other tool's misses are mostly scope, not failure: model stores, browser and IDE extensions, and offline exports sit outside what single-surface tools read.

False-positive traps. The 50 negatives include deliberate over-flag bait (crypto-exchange “Gemini” apps, an MCP2515 CAN-bus library, a ServiceNow flow named for an AI product, a “Gemini Wallet” extension). ShadowScan

flagged eight — the cost of name-based recall. No third-party tool flagged any, partly real precision, partly because most traps live on surfaces only ShadowScan reads.

Design findings. Cisco MCP Scanner inventories nothing without launching each configured server — a measured consequence of its connection-required design under a no-execution rule, not a harness failure. AgentSight's primary eBPF mode is blocked by this kernel (fentry/fexit EPERM); only its local-session fallback was graded.

6 · Reproducing this run

Everything needed is in the repository: the frozen corpus (benchmarks/shadowbench/, FREEZE.json pins SHA-256 of all 139 files), the harness (tools/shadowbench/, *python -m tools.shadowbench* validate · verify-freeze · run · score · report), pinned tool versions and raw per-command outputs in results/2026-10-11/runs.json, and the protocol with its bias statement in benchmarks/shadowbench/README.md. Runs use a scrubbed environment with a dead proxy; install the listed tool versions and re-run against the verified freeze for a faithful reproduction.